Investigando Logs do M365 Entra Id no Splunk

Irei filtrar os logs de auditoria unificada do M365 com:

index="scenario" sourcetype="o365:management:activity"

i	Time	Event
>	2/11/26 6:20:09.000 PM	


```
{ [-]
  AppAccessContext: { [+]
  }
  AppId: 9199bf20-a13f-4107-85dc-02114787ef48
  ClientAppId: 9199bf20-a13f-4107-85dc-02114787ef48
  ClientIPAddress: 2804:2488:7082:a4c0:fd97:b11b:9895:49c0
  ClientInfoString: Client=OWA;Action=ViaProxy
  CreationTime: 2026-02-11T18:20:09
  ExternalAccess: false
  Folders: [ [+]
  ]
  Id: 8379dc9e-2a06-436d-93ec-164a64eccb47
  InternalLogonType: 0
  LogonType: 0
  LogonUserSid: S-1-5-21-2637439592-1338644555-3027864711-45050765
  MailboxGuid: 9ffa2a34-aeec-4f5e-94b9-8fd90827c74f
  MailboxOwnerSid: S-1-5-21-2637439592-1338644555-3027864711-45050765
  MailboxOwnerUPN: allan.smith@finegalo.thm
  Operation: MailItemsAccessed
  OperationCount: 2
  OperationProperties: [ [+]
  ]
  OrganizationId: d3711f14-7b27-49f8-9256-37bad364169d
  OrganizationName: finegalo.thm
  OriginatingServer: GV2PR10MB9698 (15.20.4200.000)
```


Mostra todos os tipos de logs:

Operation: A ação específica realizada (por exemplo, "Nova Regra de Caixa de Entrada", "Acesso a Arquivo", "Enviar").

UserId: A conta que realizou a ação, geralmente um endereço de e-mail.

ClientIP or ClientIPAddress: O endereço IP de origem (às vezes, essa informação pode ser um endereço IP do Office 365. Certificar sempre de verificar o registro do IP do Cliente).

Workload: O serviço do M365 onde a ação ocorreu (Exchange, SharePoint, OneDrive).

ObjectId: O recurso de destino (endereço de e-mail, caminho do arquivo, caixa de correio).

Investigando Atividades Suspeitas no M365 Após a Invasão

Identificar atividades suspeitas na conta comprometida é essencial.
Aalgumas atividades comuns pós-invasão que devemos estar ciente:

- Manipulação da Caixa de Entrada:
- Criação de regras na caixa de entrada para excluir, encaminhar ou mover e-mails
- Exclusão em massa de e-mails ou movimentação para a pasta Itens Excluídos
- E-mails enviados para endereços externos
- Acesso a partir de endereços IP ou locais incomuns
- Operações com Arquivos:
- Downloads em massa de arquivos do SharePoint ou OneDrive
- Acesso a documentos confidenciais ou de nível executivo
- Compartilhamento de arquivos com domínios externos
- Downloads de arquivos que o usuário normalmente não acessaria.

Vou utilizar uma consulta Splunk aprimorada que pode servir como ponto de partida para identificar o que o invasor fez com uma conta de usuário comprometida:

```
index="scenario" sourcetype="o365:management:activity"
UserId="allan.smith@finegalo.thm"
| sort - _time
| eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
| table _time, Operation, UserId, sourceIP, Workload, ObjectId
```

_time	Operation	UserId	sourceIP	Workload	ObjectId
2026-02-11 18:20:09	MailItemsAccessed	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange	
2026-02-11 18:19:47	MailItemsAccessed	allan.smith@finegalo.thm	2603:10a6:150:1e5::20	Exchange	
2026-02-11 18:19:39	Send	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange	
2026-02-11 18:18:46	Create	allan.smith@finegalo.thm	2804:2488:7082:a4c0:fd97:b11b:9895:49c0	Exchange	
2026-02-11 18:18:10	New-InboxRule	allan.smith@finegalo.thm	[2804:2488:7082:a4c0:fd97:b11b:9895:49c0]:16321	Exchange	EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted Organizations/finegalo.thm/d15f0e8c-80f7-41c0-b861-207d79cbb734\For all messages from Kyle Taylor

Resultados da investigação

1 - Aplicativo usado pelo atacante:

Através da consulta: index="scenario" sourcetype="o365:management:activity"

Verifiquei no campo Workload que o aplicativo usado foi o Exchange.

```
Workload: Exchange
}
```

2 - Alteração feita pelo atacante no aplicativo do usuário:
Usando a consulta:

index="scenario" sourcetype="o365:management:activity"
UserId="allan.smith@finegalo.thm"
| sort - _time
| eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
| table _time, Operation, UserId, sourceIP, Workload, ObjectId

Verifiquei que o atacante realizou essas alterações em “Operation”:
New-InboxRule

18:18:10	New-InboxRule	a

3 - O Assunto da mensagem de email enviado pelo atacante:

Através dessa pesquisa: index="scenario" sourcetype="o365:management:activity" UserId="allan.smith@finegalo.thm"

Fui expandindo as informações em “FoldersItems +” e verifiquei em Subject que o assunto foi esse:

```
FolderItems: [ [-]
  { [-]
    CreationTime: 2026-02-11T18:20:09
    Id: LgAAAAAdhAMRqmYRzZvIAKoAL8RaDQAcMMbo1dgRQ4r2lA1E+en2
    ImmutableId: LgAAAAAdhAMRqmYRzZvIAKoAL8RaDQAcMMbo1dgRQ4
    InternetMessageId: <GV2PR10MB96980F09646DEA677CE30203A0
    SizeInBytes: 6784
    Subject: URGENT: Approval for new internal VPN Access
  }
```

URGENT: Approval for new internal VPN Access

4 - Data e hora que o atacante acessou a resposta da mensagem

Usando essa pesquisa:

index="scenario" sourcetype="o365:management:activity"
UserId="allan.smith@finegalo.thm"
| eval sourceIP=coalesce('ClientIP', 'ClientIPAddress')
| search Operation="MailItemsAccessed"
| table _time, Operation, ObjectId sourseIP

Apareceu a data e o horário do acesso: 2026-02-11 18:20:09

5 - O caminho a resposta foi armazenada

Através da pesquisa:
index="scenario" sourcetype="o365:management:activity"
UserId="allan.smith@finegalo.thm"


```
Folders: [ [-]
  { [-]
    FolderItems: [ [+]
    ]
    Id: LgAAAACzCizrskwgR6mkVv5h396zAQAcMMbo1dgRQ4r2lA1E
    Path: \Deleted Items
```

Conclusão

Através desse estudo compreendi o motivo dos invasores visarem o Entra ID e o M365 e as vulnerabilidades comuns que exploram.
Entendi o verdadeiro poder dos logs para a construção de uma linha do tempo completa de um ataque.
Entendi que os logs de login do Entra ID são o ponto de partida da investigação para identificar: Tentativas de autenticação suspeitas. Se um invasor se autentica com sucesso. A origem das autenticações.
Entendi que os logs de auditoria do Entra ID ajudam a identificar a escalada de privilégios no nível da identidade.
Entendi que os logs de auditoria do M365 ajudam a identificar o que o invasor fez com acesso legítimo aos aplicativos da empresa, como Outlook, SharePoint e outros.

Autor: Paulo Cesar
Formado em Segurança da informação
Apaixonado por análise de segurança, SOC, forense e investigação OSINT.